DESIGNING A PRIVACY-PRESERVING, OFFLINE MACHINE LEARNING SYSTEM FOR MALICIOUS URL DETECTION USING URL FEATURES

BY

CONNIE RODRIGUEZ

AN ADVANCED DESIGN PROJECT SUBMITTED TO THE FACULTY OF SAINT MARTIN'S UNIVERSITY IN PARTIAL FULFILLMENT OF THE REQUIREMENTS FOR THE DEGREE OF MASTER OF SCIENCE IN COMPUTER SCIENCE

SAINT MARTIN'S UNIVERSITY

MAY 7, 2026

CSC 598 CERTIFICATE OF APPROVAL

DESIGNING A PRIVACY-PRESERVING, OFFLINE MACHINE LEARNING SYSTEM FOR MALICIOUS URL DETECTION USING URL FEATURES

BY

CONNIE RODRIGUEZ

_____

Date of Acceptance

Special Committee directing the

Master's degree for Candidate

_____

Dr. Dvorak, Professor

Project Adviser

_____

Professor: _____

Committee Member

_____

Professor: _____

Ex-Officio

Abstract

This research presents the design, implementation, and evaluation of a privacy-preserving, offline machine learning system for malicious URL detection using URL-based features. Unlike many current malicious URL detection approaches that rely on external data sources such as Domain Name System (DNS) queries, WHOIS records, or webpage content analysis, this system operates solely on features derived from the URL string. This constraint enables deployment in air-gapped (i.e., isolated from external networks), privacy-sensitive, and resource-constrained environments, while supporting reproducibility and eliminating dependencies on external services. This design directly targets a gap in existing literature, where offline, privacy-preserving detection frameworks remain underexplored relative to their practical deployment need in isolated and constrained environments.

The system is implemented as a research-oriented prototype using a modular, multi-stage pipeline. The pipeline performs dataset construction, preprocessing, feature engineering (deriving lexical and structural attributes from URLs), model training, and evaluation using two real-world threat intelligence sources: PhishTank, a community verified repository of phishing URLs, and URLhaus, a curated feed of malware distribution URLs, balanced against legitimate domains from the Tranco Top Sites list. A total of 24 lexical and structural URL features are engineered and applied consistently across datasets to ensure methodological integrity and prevent data leakage. Three lightweight machine learning models, Logistic Regression, Decision Tree, and Random Forest, are trained and evaluated using stratified sampling and five-fold cross-validation.

A central contribution of this work is the evaluation of cross-dataset generalization, where models trained on one threat intelligence source are tested on another to assess their ability to maintain performance across different data sources and real-world variability. Additionally, the system introduces a single-responsibility pipeline architecture, enhancing transparency, reproducibility, and extensibility for academic and research applications.

This study contributes to cybersecurity research by analyzing the trade-offs between detection accuracy, generalization capability, computational efficiency, and privacy preservation in a fully offline detection framework. The evaluation addresses the viability of URL-only feature-based detection while examining the limitations and challenges associated with operating under strict data and environmental constraints. This work establishes a reproducible framework for future research and offers insights relevant to the potential deployment of lightweight malicious URL detection systems in constrained environments.

List of Figures and Tables

List of Figures

List of Tables

Table of Contents

CHAPTER 1: INTRODUCTION

1.1 Introduction

Phishing remains one of the most persistent and damaging forms of cybercrime, responsible for credential theft, financial fraud, identity compromise, and the initial access phase of countless other attacks [1]. By disguising malicious links as legitimate ones, attackers exploit human trust rather than software vulnerabilities, making phishing both technically simple and socially effective. Global cybersecurity reports consistently rank phishing as the leading initial attack vector, with millions of malicious URLs generated daily and increasingly sophisticated techniques appearing across the web, mobile, and email platforms [1], [2].

Despite rising user awareness, phishing remains effective because attackers rapidly adapt URL structures, domain variations, and obfuscation techniques. Traditional defensive mechanisms, such as blacklists, signature-based filters, or heuristic rules, struggle to keep pace with these evolving threats. Blacklists can only block previously identified malicious domains; heuristics can be easily bypassed through minor variations in URL length, token placement, or character composition [3]. As a result, organizations and individuals remain vulnerable to emerging zero-day phishing URLs that do not resemble known malicious patterns.

This challenge motivates the need for adaptive, data-driven detection systems that can generalize beyond known examples. Machine learning (ML) offers this adaptability. Instead of relying on fixed rules, ML models learn statistical patterns of malicious versus legitimate URLs and can classify newly observed URLs in near real-time. URL-based detection, where the classifier evaluates only the URL text rather than webpage content, offers distinct advantages. It is fast, lightweight, does not require page rendering, and is suitable for deployment in browsers, email gateways, mobile devices, and resource-constrained environments [3].

However, a critical and underexplored constraint in practical deployment scenarios is the need to operate in a fully offline, privacy-preserving environment. Many existing malicious URL detection systems rely on supplementary inputs such as Domain Name System (DNS) queries, WHOIS registration data, webpage content inspection, or cloud-based threat intelligence feeds during classification [3]. These dependencies introduce limitations in terms of data exposure risk, reliance on network connectivity, reduced reproducibility, and limited deployability in restricted or air-gapped environments. For security tools deployed on endpoint devices, within organizational intranets, or in environments where URL resolution itself poses a risk, these external dependencies are not acceptable constraints.

This project addresses that gap by implementing a privacy-preserving, offline machine learning pipeline for malicious URL detection. The system operates exclusively on 24

lexical and structural features derived from the URL string itself, with no DNS queries, WHOIS lookups, Hypertext Transfer Protocol (HTTP) requests, or external Application Programming Interface (API) calls permitted at any stage of the pipeline. This design enables deployment in air-gapped, privacy-sensitive, and resource-constrained environments while supporting full reproducibility and eliminating runtime dependencies on external services.

The system is evaluated using two real-world threat intelligence sources: PhishTank [4], a community-verified repository of phishing URLs, and URLhaus [5], a curated feed of malware distribution URLs, balanced against legitimate domains from the Tranco Top Sites list [6]. Three lightweight machine learning classifiers, Logistic Regression, Random Forest, and Decision Tree, are trained and evaluated using stratified sampling, which preserves the proportion of malicious and legitimate URLs across training and testing sets, and five-fold cross-validation, where the data is repeatedly split into five parts to provide a more reliable estimate of model performance. A central component of evaluation is cross-dataset generalization testing, where models are trained on one threat intelligence source and evaluated on the other in both directions, assessing the system's ability to maintain detection performance across distinct real-world URL distributions.

The study seeks to answer five core research questions:

1. Can 24 URL-string-only features, derived exclusively from the URL string, without reliance on DNS queries, WHOIS lookups, or external API calls, support strong phishing detection performance across two independently sourced real-world threat intelligence feeds in a fully offline, privacy-preserving environment?
2. Which URL-string features demonstrate the highest predictive stability across the datasets from different threat intelligence sources?
3. Which lightweight machine learning algorithm provides the best trade-off between classification performance and deployment feasibility for real-world phishing detection?
4. How well does a model trained on PhishTank URLs generalize when evaluated against URLhaus data, and vice versa? What performance gap, if any, exists between the two directions, and what might it reveal about the structural differences between phishing and malware delivery URLs?
5. What measurable improvements over the Iteration 1 baseline can be demonstrated through iterative feature selection and optimization across subsequent experimental rounds?

By addressing these questions, this project makes a focused and original contribution to cybersecurity research. It presents the design, implementation, and rigorous evaluation of a fully offline, privacy-preserving malicious URL detection system that operates solely

on URL-string-derived features, without external lookups, network queries, or runtime dependencies. While existing research frequently demonstrates strong detection performance by incorporating supplementary external signals, this work deliberately excludes them to establish what is achievable within the strict constraints of air-gapped, privacy-sensitive, and resource-constrained deployment environments. This design space remains underexplored in the literature relative to its practical relevance, and this project directly addresses that gap. The resulting framework provides a reproducible, transparent, and extensible baseline for future researchers and practitioners seeking to deploy lightweight malicious URL detection in environments where system independence and data privacy are non-negotiable requirements.

1.2 Background

The field of phishing detection has evolved substantially over the past few decades. Early systems focused on manually curated blacklists and heuristic rules. While computationally inexpensive, these methods are reactive and limited. Blacklists cannot identify newly generated malicious URLs, and heuristics often produce a high false positive rate or fail entirely when attackers insert deceptive tokens, alter domain structures, or use randomized characters.

The emergence of machine learning significantly advanced the field by enabling dynamic classification based on learned patterns in URL characteristics [7]. Traditional ML approaches typically rely on handcrafted lexical and structural features, such as URL length, the number of dots or hyphens, presence of digits, or whether the URL contains suspicious tokens. Algorithms such as Logistic Regression, Support Vector Machines, Random Forests, and Decision Trees demonstrated strong baseline performance [3]. These models offer interpretability and low computational overhead, making them suitable candidates for deployment in operational security tools, though they may struggle against sophisticated obfuscation and rapidly evolving phishing techniques.

More recently, deep learning approaches, including character-level convolutional neural networks (CNNs), recurrent neural networks (RNNs), and Transformer-based models, have been applied to URL classification, automatically learning representations without manual feature engineering [8]. These models have demonstrated strong performance by capturing complex lexical patterns and contextual relationships within URL strings. However, their deployment in real-time or computationally constrained environments is often limited by computational requirements, memory usage, inference latency, and reduced interpretability [8]. For environments where explainability, low overhead, and offline operation are required, lightweight interpretable classifiers remain the more appropriate choice [9].

A growing body of research highlights a key challenge that affects both lightweight and deep learning approaches equally generalization across datasets. Models trained on one dataset often exhibit significant performance degradation when tested on another dataset collected from a different time period, geographic region, source platform, or threat intelligence feed. This phenomenon, broadly referred to as dataset shift or domain shift, reveals inherent differences in URL distribution, phishing techniques, and labeling practices across sources [10]. As phishing campaigns evolve rapidly, and threat intelligence feeds capture different segments of the malicious URL ecosystem, a model's performance on a single dataset is not a reliable indicator of real-world deployment performance.

This challenge is particularly relevant when comparing phishing-specific feeds such as PhishTank, which captures credential-harvesting URLs, typically characterized by long obfuscated paths and deceptive domain structures, against malware delivery feeds such as URLhaus, which tracks botnet infrastructure URLs often characterized by IP-based hosts, higher proportions of numeric characters, and structural patterns distinct from traditional phishing [4], [5]. Models trained on one type of threat may not generalize well to the other, and quantifying this asymmetry is essential for understanding the practical limitations of URL-only detection [10], [11].

An additional constraint that has received comparatively little attention in the literature is the requirement to operate without any external data sources at inference time. Many published phishing detection systems that demonstrate strong performance incorporate external supplementary signals. While these supplementary signals improve accuracy, they introduce dependencies that are incompatible with privacy-sensitive, air-gapped, or resource-constrained deployment environments. The design space of fully offline, URL-string-only detection systems capable of maintaining strong performance without these signals remains underexplored relative to its practical deployment relevance [9], [11].

This project situates itself within this evolving research landscape by focusing on lightweight, interpretable ML classifiers operating under a strict URL-string-only feature constraint, evaluated against two independently sourced real-world threat intelligence datasets. Rather than pursuing deep learning accuracy, the project emphasizes methods that are computationally efficient, fully offline, and suitable for operational deployment [9]. The cross-dataset generalization framework directly addresses the dataset shift problem by training on one threat source and evaluating on the other in both directions, providing quantitative evidence of how well URL-structural patterns transfer across fundamentally different categories of malicious URLs, and establishing a reproducible foundation for evaluating offline phishing detection under realistic operational constraints.